Travaux pratiques – Banques des autorités de certification

Objectifs

Partie 1 : certificats approuvés par votre navigateur

Partie 2 : rechercher des attaques de type Man-In-Middle

Contexte/scénario

La sécurité suit l'évolution du web. HTTPS (où S signifie sécurité) ainsi que le concept d'autorité de certification ont été présentés par Netscape en 1994 et sont encore utilisés aujourd'hui. Au cours de ces travaux pratiques, vous allez :

- Répertorier la liste de tous les certificats approuvés par votre navigateur (sur votre ordinateur)
- Utiliser les hashs pour déterminer si votre connexion Internet est interceptée (dans la poste de travail CyberOps VM)

Ressources requises

- Poste de travail virtuel CyberOps
- Accès Internet

Instructions

Partie 1 : Certificats approuvés par votre navigateur

HTTPS s'appuie sur une entité tierce pour la validation. Appelée autorité de certification (AC), cette entité tierce vérifie si un nom de domaine appartient vraiment à l'entreprise qui prétend en être propriétaire. Lorsque c'est le cas, l'autorité de certification crée un certificat signé numériquement contenant des informations sur l'entreprise, y compris sa clé publique.

Le système entier est basé sur le fait que les navigateurs web et les systèmes d'exploitation sont fournis avec une liste d'autorités de certification dignes de confiance. Tous les certificats signés par l'une des autorités de certification dans la liste seront considérés comme légitimes par le navigateur et seront automatiquement approuvés. Pour rendre le système plus sûr et plus évolutif, les autorités de certification confient souvent la tâche de créer et de signer les certificats à des autorités de certification enfants. L'autorité de certification parente est appelée autorité de certification racine. Si un navigateur fait confiance à une autorité de certification racine, il fait également confiance à tous ses enfants.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Remarque: Alors que les banques de certificats sont semblables quel que soit le navigateur utilisé, nous nous concentrerons ici sur **Chrome 81** et **Firefox 75**. Le menu et les graphiques peuvent être différents pour d'autres versions de navigateur web.

Suivez les étapes pour afficher la banque d'AC dans votre navigateur :

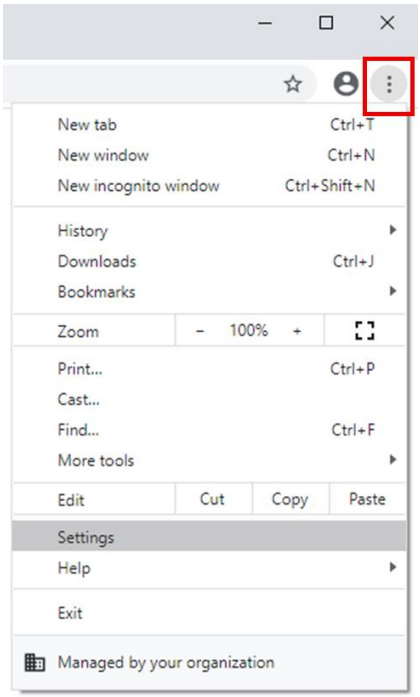
Étape 1: Affichez les certificats racine dans Chrome.

Vous pouvez effectuer cette étape sur votre ordinateur local ou utiliser FireFox sur le poste de travail virtuel CyberOps. Si vous utilisez Firefox, passez à l'étape 2. Si vous utilisez un navigateur autre que Chrome ou Firefox, recherchez sur Internet la procédure pour afficher vos certificats racine.

Remarque : le menu et les graphiques peuvent être différents pour les autres versions du navigateur Chrome.

a. Ouvrez le navigateur web Chrome sur votre PC.

b. Cliquez sur l'icône représentant trois points à l'extrémité droite de la barre d'adresse pour afficher les options de Chrome. Cliquez sur **Paramètres**.

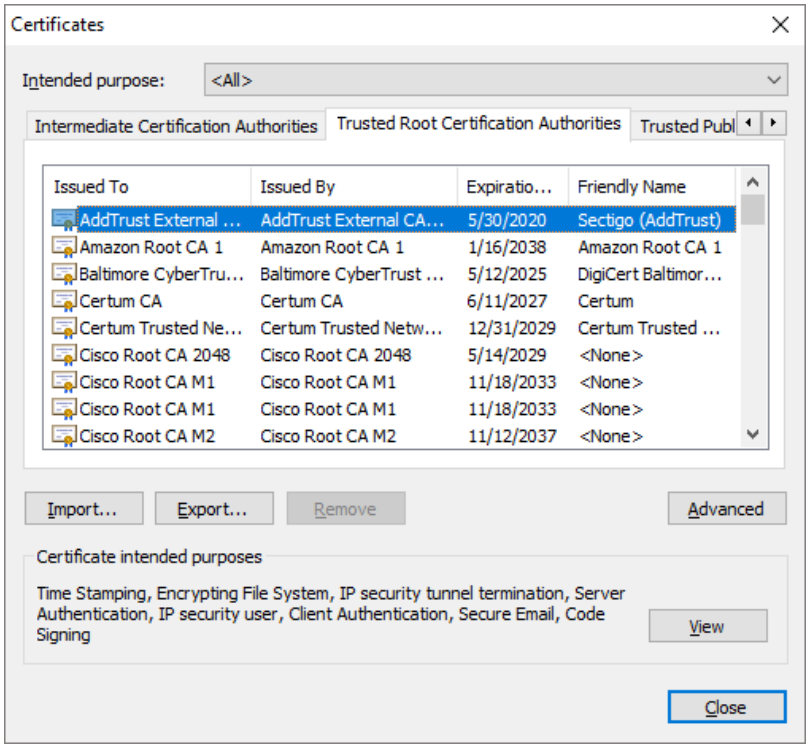


c. Faites défiler jusqu'à **Privacy and security**, puis cliquez sur **More**.

d. Sélectionnez **Manage certificates**.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

e. Dans la fenêtre Certificat, sélectionnez l'onglet **Trusted Root Certification Authorities** pour afficher tous les certificats et autorités de certification approuvés par Chrome.

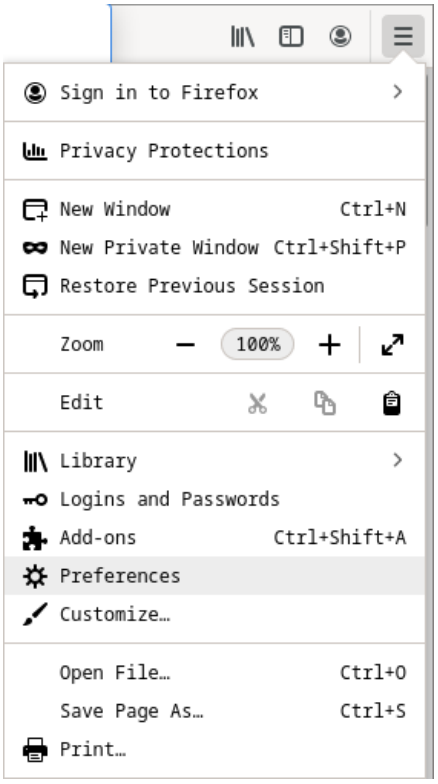


Étape 2: Affichez les certificats dans la banque d'AC dans Firefox.

Remarque : le menu et les graphiques peuvent être différents pour les autres versions du navigateur Firefox et d'un système d'exploitation à un autre. **Firefox 75** sur le poste de travail virtuel CyberOps est illustré dans cette étape.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

a. Ouvrez Firefox et cliquez sur l'icône Menu. L'icône **Menu** est située à l'extrémité droite de la fenêtre Firefox, à côté de la barre d'adresse. Cliquez sur **Preferences**.

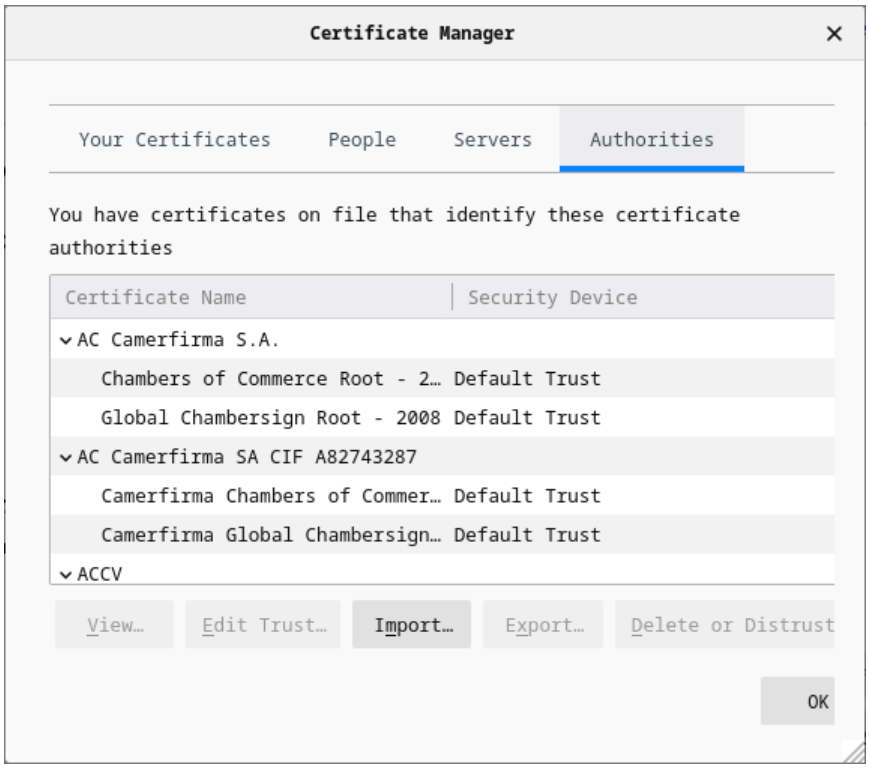


b. Cliquez sur **Privacy & Security** dans le panneau de gauche.

c. Accédez à la section Security, puis cliquez sur **View Certificates**.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

d. Une fenêtre s'ouvre et affiche les certificats et les autorités de certification approuvés par Firefox.



Partie 2 : Rechercher des attaques de type Man-In-Middle

Cette partie s'effectue via le poste de travail virtuel CyberOps.

Les hashs servent en général à vérifier l'intégrité des données, mais ils peuvent également servir à détecter les attaques de type Man-in-the-Middle HTTPS.

Pour protéger les données des utilisateurs, les sites web ont de plus en plus recourt au trafic chiffré. Appelés sites HTTPS, les sites utilisent des protocoles tels que TLS/SSL pour chiffrer entièrement le trafic des utilisateurs. Une fois que le trafic est correctement chiffré, il est très difficile pour quiconque autre que l'utilisateur et le site en question de voir le contenu du message chiffré. Bien que ce soit une bonne chose pour les utilisateurs, c'est problématique pour les entreprises qui souhaitent étudier ce trafic. Les entreprises et les organisations examinent souvent le trafic généré par leurs collaborateurs à des fins de surveillance. Elles doivent pour cela être en mesure d'étudier le trafic chiffré TLS/SSL en général à l'aide d'un proxy HTTPS.

Les navigateurs web font confiance à l'identité d'un site web visité, si le certificat présenté par ce site web est signé par l'une des autorités de certification installées dans la banque de certificats du navigateur. Pour pouvoir examiner le trafic chiffré TLS/SSL de ses utilisateurs, une entreprise ou une organisation ajoute simplement une autre AC dans la liste des AC installées du navigateur des utilisateurs.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Considérez le scénario suivant : la société X embauche un nouveau collaborateur et lui fournit un nouvel ordinateur portable. Avant de lui remettre l'ordinateur portable, le département informatique de la société installe tous les logiciels dont il a besoin pour travailler. Parmi les logiciels et les packages qui sont installés, le département informatique ajoute également une AC supplémentaire à la liste des AC approuvées. Cette AC supplémentaire pointe vers un ordinateur contrôlé par la société appelé le proxy HTTPS. Étant donné que la société contrôle le trafic, le protocole HTTPS peut être placé au milieu de n'importe quelle connexion. Cela fonctionne comme suit :

1. L'utilisateur tente d'établir une connexion sécurisée au site web HTTPS H, hébergé sur Internet. H peut être n'importe quel site HTTPS : une banque, une boutique en ligne, un serveur de messagerie, etc..
2. Étant donné que la société contrôle le trafic, elle fait en sorte que tout le trafic des utilisateurs passe par le proxy HTTPS. Le proxy HTTPS *se fait passer* pour le web site H et présente un certificat auto-signé pour prouver qu'il est le site H. Pour faire simple, le proxy HTTPS dit :« Bonjour, je suis le site HTTPS H. Voici mon certificat. Il a été signé par... moi-même ».
3. Étant donné que le certificat présenté est signé par l'une des AC incluses dans la banque d'AC de l'ordinateur portable (rappelez-vous qu'elle a été ajoutée par le département informatique), le navigateur web croit qu'il communique avec le site H. Notez que si l'AC supplémentaire n'avait pas été ajoutée à la banque d'AC, l'ordinateur portable n'approuverait pas le certificat et réaliserait immédiatement que quelqu'un d'autre essaie de *se faire passer pour* H.
4. L'ordinateur portable fait confiance à la connexion et établit un canal sécurisé avec le proxy HTTPS, croyant qu'il communique en toute sécurité avec H.
5. Le proxy HTTPS établit maintenant une deuxième connexion sécurisée à H, le site web auquel l'utilisateur tentait d'accéder dès le début.
6. Le proxy HTTPS est maintenant le point de terminaison de deux connexions sécurisées distinctes ; une établie avec l'utilisateur et l'autre avec H. Étant donné que le proxy HTTPS est le point de terminaison de ces deux connexions, il peut maintenant déchiffrer le trafic provenant de ces deux connexions.
7. Le proxy HTTPS peut maintenant recevoir le trafic TLS/SSL chiffré des utilisateurs destiné à H, le déchiffrer, l'examiner et le rechiffrer à l'aide de TLS/SSL et l'envoyer à H. Quand H répond, le proxy HTTPS inverse le processus avant de transmettre le trafic à l'utilisateur.

Notez que le processus est pratiquement transparent pour l'utilisateur, qui voit la connexion chiffrée par TLS/SSL (points verts sur le navigateur). Bien que la connexion soit sécurisée (chiffrée par TLS/SSL), elle a été établie vers un faux site web.

Même si leur présence est le plus souvent transparente pour l'utilisateur, les proxys TLS sont facilement détectables à l'aide de hashs. Dans le cas de l'exemple ci-dessus, comme le proxy HTTPS n'a pas accès aux clés privées du site H, le certificat qu'il présente à l'utilisateur est différent de celui présenté par H. Une valeur appelée *empreinte numérique* est incluse dans chaque certificat. Cette valeur, qui est un hash calculé et

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

signé par l'émetteur du certificat, est une synthèse de tout le contenu du certificat. Si une seule lettre du certificat est modifiée, l'empreinte numérique produit une valeur totalement différente. En raison de cette propriété, les empreintes numériques servent à comparer rapidement les certificats. Reprenons l'exemple ci-dessus, l'utilisateur peut demander le certificat de H et comparer l'empreinte numérique qu'il renferme avec celle fournie lors de l'établissement de la connexion au site web H. Si les empreintes numériques correspondent, la connexion à H est alors établie. Si les empreintes digitales ne correspondent pas, la connexion a été établie à un autre point de terminaison.

Suivez les étapes ci-dessous pour déterminer si un proxy HTTPS est présent pour votre connexion.

Étape 1: Récupérer les empreintes numériques correctes et non modifiées des certificats.

La première étape consiste à récupérer les empreintes numériques de quelques sites. Cette étape est importante, car ces empreintes numériques seront utilisées ultérieurement à des fins de comparaison. Le tableau suivant contient les empreintes numériques de certificats de sites populaires.

Remarque : les empreintes numériques SHA-1 indiquées dans le tableau 1 peuvent ne plus être valides, car les entreprises renouvellent régulièrement leurs certificats. L'empreinte numérique est aussi appelée Thumbprint sur les ordinateurs Windows.

Tableau 1 – Sites populaires et leurs empreintes numériques de certificat SHA-1

Site	Domaines couverts par un certificat	Certificate SHA-1 Fingerprint (as of May 2020)
www.cisco.com	www.cisco.com	E2:BD:0B:58:C6:B4:FF:91:D6:23:AB:44:0D:8F:64:76:29:4E:30:0B
www.facebook.com	*.facebook.com	BB:E7:A0:97:C7:92:B2:2D:00:38:12:69:E4:64:E9:04:96:4B:C7:41
www.wikipedia.org	*.wikipedia.org	A8:F9:F7:79:BE:DB:3E:EB:59:F0:1D:A6:34:08:A1:64:5D:28:48:44
twitter.com	twitter.com	73:33:BB:96:1D:DB:9C:0C:4F:E5:1C:FF:68:26:CF:5E:3F:50:AB:96
www.linkedin.com	www.linkedin.com	04:BC:C5:09:DD:AE:99:40:7E:99:A5:65:32:68:EC:5D:2D:D7:5A:19

Qu'est-ce qu'une empreinte numérique ? Pourquoi les empreintes numériques sont-elles importantes ?

Qui calcule les empreintes numériques ? Comment peut-on les trouver ?

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Étape 2: Récupérer l'empreinte numérique du certificat utilisé par le poste de travail virtuel CyberOps.

Maintenant que nous avons les empreintes réelles, il nous faut récupérer les empreintes numériques d'un hôte local et comparer les valeurs. Si les empreintes numériques ne correspondent pas, le certificat utilisé N'APPARTIENT PAS au site HTTPS qui est vérifié. Cela signifie donc qu'un proxy HTTPS est établi entre l'ordinateur hôte et le site HTTPS qui est vérifié. Au contraire, si les empreintes numériques correspondent, aucun proxy HTTPS n'est établi.

a. Utilisez les trois commandes séparées par une barre verticale ci-dessous pour récupérer l'empreinte numérique pour Cisco.com. La ligne ci-dessous utilise OpenSSL pour établir la connexion à cisco.com sur le port 443 (HTTPS), pour demander le certificat et pour le stocker dans un fichier texte nommé **cisco.pem**. La sortie est également indiquée pour le contexte.

```
[analyst@secOps ~]$ echo -n | openssl s_client -connect cisco.com:443 | sed -ne '/-BEGIN CERTIFICATE-/,/-END CERTIFICATE-/p' > ./cisco.pem
depth=2 C = BM, O = QuoVadis Limited, CN = QuoVadis Root CA 2
verify return:1
depth=1 C = US, O = HydrantID (Avalanche Cloud Corporation), CN = HydrantID SSL ICA G2
verify return:1
depth=0 C = US, ST = CA, L = San Jose, O = "Cisco Systems, Inc.", CN = www.cisco.com
verify return:1
TERMINÉ
```

b. Vous pouvez également utiliser la commande **cat** pour répertorier le contenu du certificat récupéré et stocké dans le fichier texte **cisco.pem** :

```
[analyst@secOps ~]$ cat cisco.pem
-----BEGIN CERTIFICATE-----
MIIG1zCCBL+gAwIBAgIUKBO9xTQoMemc9zFHNkdMW+SgFO4wDQYJKoZIhvcNAQEL
BQAwXjELMAkGA1UEBhMCVVMxMDAuBgNVBAoTJ0h5ZHJhbnRJRCAoQXZhbGFuY2hl
IENsb3VkIENvcnBvcmF0aW9uKTEdMBsGA1UEAxMUSHlkcmFudElEIFNTTCBJQ0Eg
RzIwHhcNMTcxMjA3MjIxODU1WhcNMTkxMjA3MjIyODAwWjBjMQswCQYDVQQGEwJV
UzELMAkGA1UECAwCQ0ExETAPBgNVBAcMCFNhbiBKb3NlMRwwGgYDVQQKDBNDaXNj
byBTeXN0ZW1zLCBJbmMuMRYwFAYDVQQDDA13d3cuY2lzY28uY29tMIIBIjANBgkq
yvo6dWpJdSircYy8HG0nz4+936+2waIVf1BBQXZUjNVuws74Z/eLIpl2c6tANmE0
q1i7fiWgItjDQ8rfjeX0oto6rvp8AXPjPY6X7PT1ulfhkLYnxqXHPETRwr8l5COO
MDEh95cRxATXNAlWAwLcBT7lDmrGron6rW6hDtuUPPG/rjZeZbNww5p/nT3EXX2L
Rh+m0R4j/tuvy/77YRWyp/VZhmSLrvZEYiVjM2MgCXBvqR+aQ9zWJkw+CAm5Z414
```

```
Eiv5RLctegYuBUMGTH1al9r5cuzfwEg2mNkxl4I/mtDro2kDAv7bcTm8T1LsZAO/
1bWvudsrTA8jksw+1WGAEd9bHi3ZpJPYedlL
-----END CERTIFICATE-----
[analyst@secOps ~]$
```

c. Maintenant que le certificat est enregistré dans le fichier texte **cisco.pem**, utilisez la commande suivante pour extraire et afficher son empreinte numérique :

```
[analyst@secOps ~]$ openssl x509 -noout -in cisco.pem -fingerprint -sha1
SHA1 Fingerprint=64:19:CA:40:E2:1B:3F:92:29:21:A9:CE:60:7D:C9:0C:39:B5:71:3E
[analyst@secOps ~]$
```

Remarque : la valeur de votre empreinte numérique peut être différente pour deux raisons. Premièrement, vous utilisez peut-être un système d'exploitation autre que le poste de travail virtuel CyberOps. Deuxièmement, les certificats sont actualisés régulièrement, ce qui modifie la valeur des empreintes numériques.

Quel algorithme de hash a été utilisé par OpenSSL pour calculer l'empreinte numérique ?

Pourquoi cet algorithme spécifique a-t-il été choisi ? Est-ce important ?

Étape 3: Comparer les empreintes numériques

Le tableau 1 permet de comparer l'empreinte numérique de certificat obtenue directement depuis le site HTTPS de Cisco avec celui obtenu depuis votre réseau. Pour rappel, les empreintes numériques peuvent changer au fil du temps.

Les empreintes numériques correspondent-elles ?

Qu'est-ce que cela signifie ?

Cette méthode est-elle infaillible à 100 % ?

Partie 3 : Défis (facultatif)

a. Vérifiez les empreintes numériques pour les sites indiqués dans le tableau 1 à l'aide de l'interface utilisateur graphique (GUI) de votre navigateur web.

Indices : trouvez comment afficher l'empreinte numérique à l'aide de l'interface utilisateur du navigateur. N'oubliez pas : Google est utile dans cet exercice et ,dans Windows, l'empreinte numérique est souvent appelée **empreinte ou thumbprint**.

b. Utilisez OpenSSL (partie 2, étapes 1 à 3) pour vérifier toutes les empreintes numériques figurant dans le tableau-1

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Question de réflexion

Que faudrait-il faire pour que le proxy HTTPS fonctionne ?

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco